

ISO Standards

Estimated time needed: 5 minutes

References:

- <https://www.techtarget.com/searchsecurity/tip/IT-security-frameworks-and-standards-Choosing-the-right-one>
- <https://www.iso.org/standards.html>

Standard	Description	Application
ISO/IEC 27001	This is the leading international information security management system (ISMS) standard. It outlines how to manage information security by addressing people, processes, and technology.	A cybersecurity team uses ISO/IEC 27001 to develop a comprehensive information security policy for their organization, ensuring all security aspects are covered.
ISO/IEC 27002	Provides best practice recommendations on information security controls for those responsible for initiating, implementing, or maintaining ISMS.	IT professionals reference ISO/IEC 27002 when selecting and implementing security controls to protect company data against cyber threats.
ISO/IEC 27017	Offers guidelines on information security controls for cloud services, making it crucial for organizations that rely on cloud computing.	A cloud services provider applies ISO/IEC 27017 guidelines to secure their platforms and services, ensuring customer data is protected.
ISO/IEC 27018	Establishes commonly accepted control objectives, controls, and guidelines for protecting personally identifiable information (PII) in public clouds acting as PII processors.	Cloud computing companies use ISO/IEC 27018 to demonstrate compliance with privacy laws and regulations, enhancing trust with users.
ISO/IEC 27701	An extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management, provides guidance for protecting privacy, including how organizations should manage personal information.	Organizations implement ISO/IEC 27701 to strengthen their privacy management system, ensuring customers' personal information is handled securely.
ISO/IEC 27032	Focuses on cybersecurity, guiding the enhancement of cyberspace security, which is vital for protecting confidentiality, integrity, and availability of information in cyberspace.	Cybersecurity experts use ISO/IEC 27032 to develop strategies for protecting against cyber attacks.
ISO/IEC 27005	Provides information security risk management guidelines in an organization, supporting the requirements of an ISMS based on ISO/IEC 27001.	An IT manager uses ISO/IEC 27005 to identify, assess, and manage information security risks, creating a risk treatment plan.
ISO/IEC 27035	Outlines incident management principles, including detecting, reporting, and assessing information security incidents.	Security teams follow ISO/IEC 27035 to establish an incident response plan, ensuring quick and effective action during a security breach.
ISO/IEC 15408	Defines a common framework for evaluating the security properties of IT products and systems, offering a comprehensive set of guidelines for developing secure IT products.	Developers refer to ISO/IEC 15408 when designing and testing new software to meet specific security criteria and ensure product integrity.

Summary

ISO standards are the leading international information security management system (ISMS) standards. They define the guidelines to manage information security by addressing people, processes, and technology. The standards include guidelines for security controls for cloud services, protection for personally identifiable information (PII) in public clouds, cybersecurity, incident management, and IT products.

Author

Dee Dee Collette

